



Artefactos Scrum — Sprint 12

Comunicación — Tablón de anuncios del edificio: el admin publica comunicados (por categoría y prioridad, con imagen opcional, con la opción de fijarlos y darles vigencia) y cada residente los ve al instante en un tablón, con indicador de no leído y la posibilidad de marcarlos como leídos · Chore: checklist OWASP top 10 (control de acceso + sanitización del contenido) · DoD v3 (segunda aplicación)

Producto	Zity
Sprint	Sprint 12 — Semana 14
Stack	React 19 + Vite 8 + TailwindCSS 4 · Supabase (Postgres + Auth + Storage + Realtime) · Resend · Vercel · GitHub Actions · Vitest · Playwright (E2E, DoD v3) · Recharts (S7) · pdf-lib (S9) · pg_cron (S9)
Product Owner	Alvarez Rocca Jaqueline
Scrum Master	Meza Pelaez Carlos
Developers	Cortez Zamora Leonardo Fabian · Gonza Morales Yoel Ronaldo · Santiago Flores Carlos Steven
Capacidad semanal	3 h/día × 5 integrantes = 15 horas/semana · 60 horas/mes
Horas estimadas	13 horas (2 horas de buffer)
DoD aplicable	DoD v3 — segunda aplicación (suma la checklist OWASP top 10 como criterio de seguridad, además de E2E, regresión y no-PII ya vigentes desde el S11)
Nuevo en este sprint	Módulo de Comunicación — Tablón de anuncios: tablas anuncios / anuncio_lecturas + RLS (solo el admin publica) + bucket anuncios-adjuntos · /admin/anuncios con CRUD de comunicados (categoría, prioridad, imagen, fijar, vigencia) · /residente/anuncios con feed, badge de no leído y marcar como leído · aviso Realtime + badge en la navbar al publicar (reusa el sistema del S6) · filtro por categoría y anuncios fijados

Chore técnico del Sprint	Checklist OWASP top 10 en los endpoints de anuncios, con foco en A01 (control de acceso: solo el admin publica), A03 (sanitización del contenido para evitar XSS, por ser contenido publicado que ven todos los residentes) y A05 (configuración). Cumple el criterio de seguridad de DoD v3. 2 h, P2.
Recolocación del Sprint	En el Sprint 11 Review el equipo recolocó el S12: el Web Push avanzado (Service Worker + VAPID) pasa a mejora opcional post-curso —las notificaciones Realtime + email del S6 ya cubren el aviso— y entra el Tablón de anuncios, un entregable más visible, cotidiano y simple de añadir.
Variables nuevas	Ninguna. El tablón de anuncios reusa Storage, Realtime y Resend ya configurados.
Emergente absorbido	PBI-S9-E02 (recordatorio de factura también el día del vencimiento, 1 h) se entrega dentro del buffer del Sprint, reusando el fixture de tiempo determinista (Acción 2 del Retro S11).
Nota	Documento académico — Datos ficticios sin PII real

Documento vivo — se actualiza en cada Sprint Review

1 ACTA DE SPRINT PLANNING

Sprint	Sprint 12 — Semana 14
Fecha	Lunes — inicio de semana 14
Duración del evento	75 minutos + 30 min de Refinement con spike de sanitización de contenido y validación del feed en móvil
Facilitador	Meza Pelaez Carlos (Scrum Master)
Asistentes	Alvarez Rocca Jaqueline (PO), Meza Pelaez Carlos (SM), Cortez Zamora Leonardo, Gonza Morales Yoel, Santiago Flores Carlos (Devs)
Stakeholder invitado	Laura Vega (Residente ficticia) — como receptora de los comunicados, valida qué información necesita ver de cada anuncio y cómo distinguir de un vistazo los urgentes. Quinta aplicación de la Acción 2 del Retro S8.
Capacidad	15 horas disponibles · se usarán 13 h (2 h de buffer)
Entrada	Product Backlog tras Sprint 11 Review. La tienda quedó cerrada (Epic TIENDA-01) y la DoD v3 inaugurada (E2E + no-P11). En el Sprint 11 Review el equipo recolocó el S12: en lugar del Web Push avanzado (que se mantiene como mejora opcional post-curso, ya que las notificaciones Realtime + email del S6 cubren el aviso), entra el Tablón de anuncios — un canal de comunicación oficial, visible y cotidiano. El chore OWASP cumple el criterio de seguridad de DoD v3. Se absorbe PBI-S9-E02 con el buffer.
Refinement previo	Octava aplicación de la práctica. 'Edge cases del dominio': «¿el cuerpo del anuncio admite HTML/markdown y cómo evitar XSS?», «¿todos los anuncios notifican o solo los importantes?», «¿cómo se marca y se sincroniza lo leído?». Spike de sanitización de contenido publicado. Se reusa el fixture de tiempo determinista (Acción 2 del Retro S11) para el E2E del recordatorio.

"Sprint Goal: Abrir el canal de comunicación oficial del edificio: el admin publica comunicados (por categoría y prioridad, con imagen opcional, con la opción de fijarlos y darles vigencia) y cada residente los ve al instante en un tablón, con indicador de no leído y la posibilidad de marcarlos como leídos. En paralelo, el chore OWASP top 10 cubre el criterio de seguridad de DoD v3, con foco en el control de acceso y la sanitización del contenido."

Nota: Segunda aplicación de DoD v3. El chore OWASP cumple el criterio de seguridad (con foco en A01 control de acceso y A03 sanitización/XSS, relevante por ser contenido publicado que ven todos los residentes). El tablón reusa el sistema de notificaciones Realtime del S6, sin nueva infraestructura. Las notificaciones push avanzadas (Web Push) se mantienen como mejora opcional post-curso. Lighthouse (S13) y release candidate (S14) completan la DoD v3.

PBIs seleccionados — Sprint 12

ID	Historia / Tarea	Tipo	Prior.	Horas	Responsable
HU-ANUNCIO-01	Modelado BD: tablas anuncios y anuncio_lecturas + RLS (solo admin publica) + bucket anuncios-adjuntos	Historia	● P1	2 h	Gonza Morales
HU-ANUNCIO-02	Vista /admin/anuncios: CRUD de comunicados (categoría, prioridad, imagen, fijar, vigencia)	Historia	● P1	3 h	Gonza Morales
HU-ANUNCIO-03	Vista /residente/anuncios: feed con badge de no leído y marcar como leído	Historia	● P1	3 h	Santiago Flores
HU-ANUNCIO-04	Aviso Realtime + badge de no leídos en la navbar al publicar (reusa S6)	Historia	● P2	2 h	Santiago Flores
Mejora	Filtro por categoría + anuncios fijados (destacados arriba)	Mejora	● P3	1 h	Santiago Flores
Chore-T	Checklist OWASP top 10 en anuncios (A01 acceso, A03 XSS/sanitización, A05 config)	Chore	● P2	2 h	Cortez Zamora
Buffer	PBI-S9-E02 (recordatorio el día del vencimiento, 1 h) + imprevistos de sanitización / adjuntos	—	● —	2 h	—

Total estimado: 13 horas comprometidas + 2 h de buffer (el buffer absorbe PBI-S9-E02, 1 h, recordatorio el día del vencimiento).

Decisiones técnicas del Sprint

Antes de empezar el desarrollo, el equipo cierra las siguientes decisiones técnicas:

Decisión	Detalle	Registrado en
Modelo de anuncios	Tabla anuncios (id, titulo, cuerpo, categoria enum [aviso/mantenimiento/asamblea/seguridad/general], prioridad enum [normal/importante/urgente], imagen_url, fijado boolean, vigente_hasta, publicado_por, created_at). La baja es lógica (archivado), nunca DELETE.	Migración 013 + ADR-015
Estado de lectura por residente	Tabla anuncio_lecturas (anuncio_id, residente_id, leído_at) con PK compuesta; es la fuente de verdad del badge 'no leído'. El contador se recalcula desde BD, no en memoria.	Migración 013 + ADR-015
RLS del tablón	anuncios: SELECT para cualquier usuario autenticado (residentes y técnicos leen); solo admin INSERT/UPDATE. anuncio_lecturas: cada residente solo la suya. Cada política se cubre con un test de los 3 roles.	Migración 013 (RLS)
Sanitización del contenido (XSS)	El cuerpo admite markdown limitado y se sanitiza en servidor (se neutraliza HTML/script) antes de guardar y al renderizar, por ser contenido publicado que ven todos los residentes. Criterio A03 de OWASP.	Chore-T + ADR-016

Decisión	Detalle	Registrado en
Aviso en vivo (reusa S6)	Al publicar, se emite una notificación por el canal Realtime del S6 (campana + badge de no leídos en la navbar). Solo los anuncios 'importante'/'urgente' fuerzan notificación para no hacer spam; los 'normal' aparecen en el feed sin notificar.	ADR-016 + reusa S6
Adjunto / imagen	Bucket anuncios-adjuntos en Storage (reusa el patrón de solicitudes-fotos del S3 y productos-fotos del S10). Validación (JPEG/PNG/PDF, ≤ 2 MB) con preview. Sin adjunto → solo texto.	ADR-016 + /docs/storage.md

Desglose de tareas — ¿Cómo?

Gonza Morales Yoel — HU-ANUNCIO-01 + HU-ANUNCIO-02 (5 h)

Tarea	Horas
Migración 013: tablas anuncios y anuncio_lecturas + enums (categoria, prioridad) + RLS (solo admin publica, autenticados leen) + bucket anuncios-adjuntos con políticas + tests de integración con los 3 roles.	2 h
Vista /admin/anuncios: listado (vigentes y archivados) + formulario de alta/edición (título, cuerpo, categoría, prioridad, imagen, fijar, vigencia). Sanitización del cuerpo en servidor. Archivado (baja lógica). Registro en audit_log.	3 h

Santiago Flores Carlos — HU-ANUNCIO-03 + HU-ANUNCIO-04 + Mejora (6 h)

Tarea	Horas
Vista /residente/anuncios: feed de tarjetas (título, categoría con color, prioridad, fecha y extracto) con badge 'Nuevo' por no leído; el detalle muestra el cuerpo (markdown sanitizado) y el adjunto. Marcar como leído actualiza el estado.	2.5 h
Aviso Realtime al publicar (reusa el canal del S6): campana + badge de no leídos en la navbar, en vivo. Solo 'importante'/'urgente' fuerzan notificación.	2 h
Filtro por categoría + anuncios fijados destacados arriba; validación del feed en móvil (360 px) con los breakpoints del spike.	1.5 h

Cortez Zamora Leonardo — Chore técnico: OWASP + emergente del buffer (2 h)

Tarea	Horas
Aplicar la checklist OWASP top 10 a los endpoints de anuncios: A01 (control de acceso: solo admin publica — RLS), A03 (sanitización del contenido para evitar XSS) y A05 (configuración). Documentar en /docs/seguridad/owasp-checklist.md.	1.5 h
PBI-S9-E02 (buffer): recordatorio de factura también el día del vencimiento, reusando el fixture de tiempo determinista (Acción 2 del Retro S11) en su E2E.	0.5 h

Riesgos del Sprint 12

#	Riesgo	Prob.	Impacto	Mitigación
R1	El contenido de un anuncio podría incluir HTML / script malicioso (XSS) visible para todos los residentes.	● Media	● Alto	Sanitización del cuerpo en servidor (markdown limitado; se neutraliza HTML/script) + render seguro. Criterio A03 del chore OWASP. Test con payload <script>.
R2	Un residente o técnico podría publicar o editar anuncios si la RLS falla.	● Baja	● Alto	RLS: solo admin INSERT/UPDATE; residentes y técnicos solo SELECT. Criterio A01 del chore OWASP. Test de los 3 roles.
R3	El badge de 'no leído' queda desincronizado con lo realmente leído.	● Baja	● Bajo	anuncio_lecturas es la fuente de verdad; el contador se recalcula desde BD al marcar leído (no en memoria).
R4	Un adjunto de imagen / PDF sin validar satura Storage o rompe el feed.	● Media	● Medio	Validación de tipo / peso (JPEG/PNG/PDF, ≤ 2 MB); reusa el patrón probado de solicitudes-fotos (S3).
R5	Notificar cada anuncio genera spam y los residentes terminan ignorando el aviso.	● Media	● Bajo	Solo los anuncios 'importante'/'urgente' fuerzan notificación; los 'normal' aparecen en el feed sin notificar.
R6	Un anuncio urgente se pierde entre muchos comunicados del tablón.	● Baja	● Bajo	Los anuncios 'fijados' y de prioridad 'urgente' se destacan arriba con color; el resto va por fecha.
R7	Anuncios vencidos saturan el tablón con el tiempo.	● Baja	● Bajo	Campo vigente_hasta + archivado; el feed muestra los vigentes y deja el histórico accesible.

2 REGISTRO DE DAILY SCRUMS

Referencia Scrum: la Daily Scrum inspecciona el progreso hacia el Sprint Goal y adapta el Sprint Backlog. Duración máxima: 15 minutos.

**"Sprint Goal: Tablón de anuncios: el admin publica comunicados (categoría, prioridad, imagen, fijar) y el residente los recibe al instante con badge de no leído.
Chore: OWASP top 10 (acceso + sanitización) en anuncios."**

Daily Scrum — Día 1 (Lunes)

DÍA	Lunes — Día 1
Progreso hacia el objetivo	Migración 013 lista: tablas anuncios y anuncio_lecturas con enums (categoría, prioridad), RLS (solo admin publica, autenticados leen) y bucket anuncios-adjuntos. Tests de los 3 roles en verde. Vista /admin/anuncios con el CRUD básico (título, cuerpo, categoría, prioridad). El spike de sanitización dejó claro el enfoque: markdown limitado + saneado en servidor.
Plan siguiente 24h	Gonza: completar /admin/anuncios (imagen, fijar, vigencia, archivado). Santiago: feed /residente/anuncios con badge de no leído. Cortez: arranca la checklist OWASP de los endpoints de anuncios.
Impedimentos	Discutimos si el cuerpo admite HTML, markdown o solo texto. Decisión: markdown limitado y sanitizado en servidor (sin HTML/script) para no abrir XSS. Capturado como edge case en el Refinement.
Ajuste Sprint Backlog	Sin cambios.

Daily Scrum — Día 2 (Martes)

DÍA	Martes — Día 2
Progreso hacia el objetivo	/admin/anuncios completo: Carlos publica un comunicado con imagen, lo fija y le pone vigencia. Feed /residente/anuncios mostrando las tarjetas con categoría (color) y prioridad, y el badge 'Nuevo'. Aviso Realtime al publicar (reusa el canal del S6) en pruebas. Validación del adjunto funcionando.
Plan siguiente 24h	Santiago: marcar como leído + badge de no leídos en la navbar + filtro por categoría + fijados. Gonza: pulir la sanitización y el archivado. Cortez: cerrar OWASP (A01/A03/A05) + aplicar el fixture de tiempo al E2E del recordatorio (PBI-S9-E02).
Impedimentos	El aviso se disparaba para todos los anuncios (también los 'normal'), generando ruido; se acotó a 'importante'/'urgente'. Corregido en el día.
Ajuste Sprint Backlog	Sin cambios. Se usa ~1 h del buffer para PBI-S9-E02 (recordatorio el día del vencimiento).

Daily Scrum — Día 3 (Miércoles)

DÍA	Miércoles — Día 3
Progreso hacia el objetivo	Tablón completo y demostrable: Carlos publica un comunicado y Laura (con la app abierta) lo ve aparecer al instante con badge 'Nuevo'; al leerlo, el contador de no leídos baja. Filtro por categoría y anuncios fijados operativos. Checklist OWASP aplicada (A01 acceso, A03 sanitización/XSS, A05 config) y documentada. E2E 'admin publica → residente recibe y lee' en verde. PBI-S9-E02 entregado con el buffer.
Plan siguiente 24h	Santiago: pulir el feed en móvil (360 px). Gonza: guión de la Sprint Review. Cortez: ensayar la demo del control de acceso y de la sanitización (payload <script>) en pantalla compartida.
Impedimentos	El badge de no leídos no bajaba al instante al marcar leído (caché); se corrigió recalculando desde BD. Sin impedimento mayor.
Ajuste Sprint Backlog	Sin cambios.

3 ACTA DE SPRINT REVIEW

Referencia Scrum: la Sprint Review inspecciona el resultado del Sprint y determina adaptaciones futuras. Es una sesión de trabajo, no una presentación.

Sprint	Sprint 12 — Semana 14
Fecha	Viernes — cierre de semana 14
Duración	55 minutos
Facilitador	Alvarez Rocca Jaqueline (PO)
Scrum Team	Alvarez Rocca Jaqueline (PO), Meza Pelaez Carlos (SM), Cortez Zamora Leonardo, Gonza Morales Yoel, Santiago Flores Carlos
Stakeholders	Laura Vega (Residente — recibe los comunicados), Carlos Fuentes (Admin — publica), Sra. Rosa Díaz (Dueña — observadora; le interesan el canal de comunicación y la participación de cara al dashboard ejecutivo del S14), Profesor del curso
Modalidad de demo	Dos navegadores (admin publica + residente recibe en vivo). Se demuestra el control de acceso (un residente no puede publicar) y la sanitización (un payload <code><script></code> queda neutralizado).

Guión de demostración

1. Carlos (admin) abre /admin/anuncios y publica un comunicado: 'Corte de agua programado', categoría 'mantenimiento', prioridad 'importante', con una imagen. Lo fija para destacarlo arriba.
2. Laura (residente, con la app abierta) ve aparecer el anuncio al instante (Realtime) en /residente/anuncios con el badge 'Nuevo'; la campana de la navbar suma 1.
3. Laura abre el anuncio, ve la imagen y el detalle; al leerlo, el badge 'Nuevo' desaparece y el contador de no leídos baja.
4. Carlos publica un segundo anuncio, 'Asamblea general', categoría 'asamblea', con un PDF adjunto y prioridad 'urgente'.
5. Laura filtra el tablón por categoría 'mantenimiento': queda el comunicado de 'Corte de agua', que además aparece destacado arriba por estar fijado.
6. Se muestra el control de acceso: Laura (residente) no ve el botón 'Publicar'; un intento directo de publicar como residente es rechazado por la RLS (OWASP A01).
7. Se muestra la sanitización: al intentar publicar un anuncio con un `<script>` en el cuerpo, queda neutralizado (se renderiza como texto, no se ejecuta) — OWASP A03.
8. Cierre del buffer: avance de tiempo simulado muestra el recordatorio de factura también el día del vencimiento (PBI-S9-E02), con su E2E en verde gracias al fixture de tiempo determinista.

"✓ CUMPLIDO: Tablón de anuncios operativo — el admin publica comunicados (categoría, prioridad, imagen, fijar, vigencia) y el residente los recibe al instante (Realtime), con badge de no leído y marcar como leído. El control de acceso (solo el admin publica) y la sanitización del contenido quedaron verificados con la checklist OWASP (criterio de seguridad de DoD v3). Sprint cerrado usando el buffer para PBI-S9-E02; octavo Sprint consecutivo sin hotfixes."

Feedback de stakeholders

Laura Vega (Residente)

- «Tener un tablón oficial con los avisos del edificio en un solo lugar es comodísimo; antes me enteraba a medias por el grupo de WhatsApp.» → Validación.
- «Para los urgentes, me gustaría recibir además un correo, por si no abro la app ese día.» → PBI-S12-E01: 'Anuncios urgentes también por email (reusa Resend)'. P3, 1.5 h. Candidato para Sprint 13.

Carlos Fuentes (Administrador)

- «Publicar un comunicado con imagen y fijarlo arriba es justo lo que necesitaba para los avisos importantes.» → Validación.
- «Me gustaría saber cuántos residentes ya leyeron un anuncio.» → PBI-S12-E02: 'Indicador de lectura para el admin (cuántos residentes leyeron)'. P2, 2 h. Candidato para Sprint 13.

Sra. Rosa Díaz (Dueña — observadora)

- «Un canal de comunicación formal le da seriedad a la administración; ver la participación (lecturas) en el dashboard del cierre (S14) sería ideal.» → Validación + insumo del S14.

Profesor del curso

- «El tablón es una funcionalidad muy visible y cotidiana; y aplicar OWASP con foco en sanitización (XSS) por ser contenido publicado es exactamente el riesgo correcto a cubrir.» → Validación de DoD v3 (seguridad).
- «Recolocar el Web Push como mejora opcional y priorizar un entregable demostrable fue una buena decisión de producto, coherente con el enfoque funcional del roadmap.» → Validación.

Decisiones de adaptación del Product Backlog

Decisión	Detalle
DoD v3 — seguridad cubierta	La checklist OWASP top 10 (A01/A03/A05) cumple el criterio de seguridad. Quedan Lighthouse (chore del S13) y release candidate (S14).
Cero hotfixes	Octavo Sprint consecutivo sin hotfixes — práctica consolidada.
Canal de comunicación abierto	El edificio cuenta con un tablón oficial de anuncios en vivo; reusa el sistema Realtime del S6 sin nueva infraestructura.
Web Push diferido	Las notificaciones push avanzadas (Service Worker + Web Push) se mantienen como mejora opcional post-curso: las notificaciones Realtime + email del S6 ya cubren el aviso.
PBI-S9-E02 entregado	El recordatorio de factura también el día del vencimiento se entregó dentro del buffer del Sprint, cerrando una deuda pequeña del S9.

Decisión	Detalle
PBI-S12-E01 (NUEVA)	Anuncios urgentes también por email (feedback Laura). P3, 1.5 h. Candidato S13.
PBI-S12-E02 (NUEVA)	Indicador de lectura para el admin (feedback Carlos). P2, 2 h. Candidato S13.
Sprint 13 confirmado	Panel integral del residente: una sola vista con 3 tarjetas (solicitudes activas, facturas pendientes, pedidos del mes) + sesiones activas. Chore: auditoría Lighthouse (≥ 80).

4 ACTA DE SPRINT RETROSPECTIVE

Referencia Scrum: la Retrospective planifica formas de aumentar calidad y efectividad. Los cambios más impactantes pueden entrar al Sprint Backlog del próximo Sprint.

Sprint	Sprint 12 — Semana 14
Fecha	Viernes — después de la Sprint Review
Duración	30 minutos
Facilitador	Meza Pelaez Carlos (Scrum Master)
Participantes	Todo el Scrum Team (PO + SM + Developers)

✓ ¿Qué salió bien?

- Las tres acciones del Retro S11 se aplicaron: el test de concurrencia quedó como patrón documentado (Acción 1); el E2E del recordatorio usó un fixture de tiempo determinista (Acción 2); y los ciclos de vida de estado quedaron en conventions.md (Acción 3).
- Reusar el sistema de notificaciones Realtime del S6 hizo que el aviso de 'anuncio nuevo' fuera casi gratis, sin nueva infraestructura.
- Decidir sanitizar el contenido desde el Día 1 evitó una vulnerabilidad de XSS antes de que existiera.
- Reusar el patrón de Storage (solicitudes-fotos / productos-fotos) para los adjuntos ahorró tiempo: misma validación, mismas URLs firmadas.
- Priorizar una funcionalidad visible y cotidiana (el tablón) sobre el push avanzado mantuvo el espíritu del roadmap (entregable demostrable) y simplificó el Sprint.
- Octavo Sprint consecutivo sin hotfixes.

✗ ¿Qué salió mal?

- El aviso se disparaba para todos los anuncios al inicio (también los 'normal'), generando ruido; se acotó a 'importante'/'urgente', pero pudo definirse en el Refinement.
- El debate markdown vs. texto plano para el cuerpo tomó tiempo; se resolvió con markdown limitado y sanitizado.
- El badge de no leídos no bajaba al instante al marcar leído (caché); se corrigió recalculando desde BD.

Acciones de mejora (máx. 3)

Acción 1 — Definir la política de notificación antes de implementar

Descripción	Antes de implementar un evento que notifique, definir en conventions.md qué eventos notifican, a quién y con qué prioridad, para no generar spam ni avisos de más.
Dueño	Santiago Flores Carlos
Evidencia	/docs/conventions.md con la sección 'Política de notificaciones' aplicada en el S13

Fecha	Sprint 13
--------------	-----------

Acción 2 — Sanitización de todo texto enriquecido como patrón

Descripción	Toda entrada de texto que se publique y se renderice a otros usuarios (anuncios, comentarios futuros) pasa por la misma sanitización en servidor. Se vuelve parte del checklist de revisión.
Dueño	Gonza Morales Yoel
Evidencia	/docs/seguridad/sanitizacion.md con el patrón + su uso en el S13
Fecha	Sprint 13

Acción 3 — Auditoría Lighthouse temprana (no al final)

Descripción	El panel integral del residente (S13) corre Lighthouse desde el primer día de desarrollo, no al cierre, para llegar a ≥ 80 sin sustos (enlaza con el chore Lighthouse del S13).
Dueño	Cortez Zamora Leonardo
Evidencia	El acta de Daily del S13 registra una corrida Lighthouse temprana
Fecha	Sprint 13

Verificación DoD v3 — segunda aplicación

Criterio	Estado
Todo lo de DoD v2 (lint, unit + integration, cobertura $\geq 60\%$, /health, Secrets, tsc, CD con verificación)	✓ CUMPLIDO
E2E mínimos de módulos críticos (publicar → leer anuncio + recordatorio con fixture de tiempo) en pipeline	✓ CUMPLIDO
Regresión: tocar un flujo crítico dispara unit + integration + E2E	✓ CUMPLIDO
Evidencia de no-PII en logs (anuncio_lecturas guarda IDs, no PII; vigente desde el S11)	✓ CUMPLIDO
Checklist OWASP top 10 aplicada (A01 acceso, A03 sanitización / XSS, A05 config en anuncios)	✓ CUMPLIDO — chore del Sprint
Performance: Lighthouse ≥ 80 en rutas principales	PROGRAMADO — chore del S13
Release candidate etiquetado + demo final reproducible	PROGRAMADO — S14
ADR-015 (modelo del tablán) + ADR-016 (sanitización + aviso Realtime) documentados	✓ CUMPLIDO — adicional a DoD v3

"DoD v3 con el criterio de seguridad (OWASP top 10, con foco en sanitización por ser contenido publicado) cumplido en este Sprint; quedan Lighthouse (S13) y release candidate (S14) con Sprint y dueño asignados. El edificio queda con su canal de comunicación oficial. Sprint 12 cerrado usando el buffer para PBI-S9-E02; octavo Sprint consecutivo sin hotfixes."

5 HISTORIAS DE USUARIO — SPRINT 12

Módulo COMUNICACIÓN — Tablón de anuncios — Sprint 12

HU-ANUNCIO-01 · Modelado BD del tablón · Tablas + RLS + bucket

Sprint 12 · 2 h

P1 · 2 h

Como **sistema**, quiero **las tablas anuncios y anuncio_lecturas con RLS (solo el admin publica) y un bucket de adjuntos**, para soportar el tablón de comunicados del edificio.

Criterios de aceptación

- Migración 013 crea anuncios (id, titulo, cuerpo, categoria enum, prioridad enum, imagen_url, fijado, vigente_hasta, publicado_por, created_at) y anuncio_lecturas (anuncio_id, residente_id, leído_at) con PK compuesta.
- RLS: anuncios SELECT para cualquier usuario autenticado; solo admin INSERT/UPDATE. anuncio_lecturas: cada residente solo la suya.
- Bucket anuncios-adjuntos en Storage con políticas (admin escribe, lectura autenticada) — reusa el patrón de solicitudes-fotos (S3).
- La baja de un anuncio es lógica (archivado), nunca DELETE: sale del tablón pero queda en el histórico.
- Tests de integración con los 3 roles validan las políticas RLS.

Evidencia: Migración 013 aplicada en staging; RLS verificada con tests automatizados; un residente no puede insertar anuncios. ADR-015 documenta el modelo.

HU-ANUNCIO-02 · Admin publica y gestiona comunicados

Sprint 12 · 3 h

P1 · 3 h

Como **administrador**, quiero **publicar y gestionar comunicados con categoría, prioridad e imagen**, para informar al edificio desde un canal oficial.

Criterios de aceptación

- Vista /admin/anuncios con listado (vigentes y archivados) + formulario de alta/edición (título, cuerpo, categoría, prioridad, imagen opcional, fijar, vigencia).
- El cuerpo admite markdown limitado y se sanitiza en servidor (sin HTML/script) antes de guardar.
- Imagen / adjunto a anuncios-adjuntos (JPEG/PNG/PDF, ≤ 2 MB) con preview; sin adjunto → solo texto.
- 'Fijar' destaca el anuncio arriba del tablón; 'vigencia' (vigente_hasta) lo retira automáticamente al expirar.
- Archivar (baja lógica) lo retira del tablón pero lo conserva en el histórico. Toda alta/edición/archivado registra en audit_log.

Evidencia: Carlos publicó 'Corte de agua' con imagen y lo fijó; editó y archivó otro comunicado; ambas acciones quedaron registradas en el audit_log.

Como **residente**, quiero **ver los comunicados del edificio en un tablón con indicador de no leído**, para estar al día de lo que informa la administración.

Criterios de aceptación

- Vista /residente/anuncios con feed de tarjetas: título, categoría (color), prioridad, fecha y extracto; los fijados aparecen destacados arriba.
- Badge 'Nuevo' en los anuncios que el residente aún no ha leído; el detalle muestra el cuerpo (markdown sanitizado) y el adjunto.
- 'Marcar como leído' (o abrir el detalle) registra la lectura en anuncio_lecturas y quita el badge.
- Solo se muestran anuncios vigentes (vigente_hasta) y no archivados; la RLS garantiza acceso de solo lectura.
- Responsiva: 1 columna en móvil (≤ 640 px), 2-3 en desktop.

Evidencia: Laura vio el tablón con el comunicado fijado arriba, abrió el detalle con la imagen y el badge 'Nuevo' desapareció al leerlo.

Como **residente**, quiero **enterarme al instante cuando se publica un comunicado importante**, para no perderme avisos relevantes.

Criterios de aceptación

- Al publicar un anuncio 'importante'/'urgente', se emite una notificación por el canal Realtime del S6 (campana) y el badge de no leídos de la navbar se incrementa en vivo.
- Los anuncios 'normal' aparecen en el feed sin forzar notificación (para no hacer spam).
- El badge de no leídos refleja el conteo real desde anuncio_lecturas y baja al marcar leído.
- Reusa el sistema de notificaciones del S6 (sin nueva infraestructura).

Evidencia: Con la app abierta, Laura recibió la campana y el badge subió al instante cuando Carlos publicó 'Asamblea general'; al leerlo, el badge bajó.

Como **residente**, quiero **filtrar el tablón por categoría y ver primero los anuncios fijados**, para encontrar rápido lo que me interesa.

Criterios de aceptación

- Filtro por categoría (aviso / mantenimiento / asamblea / seguridad / general / todas) en la cabecera del tablón.
- Los anuncios 'fijados' por el admin se muestran destacados arriba, por encima del orden por fecha.
- El filtro y los fijados se combinan de forma coherente.

Evidencia: Laura filtró por 'mantenimiento' y el comunicado de 'Corte de agua' (fijado) quedó destacado arriba.

Chore técnico del Sprint: Checklist OWASP top 10 aplicada a los endpoints de anuncios, con foco en A01 (control de acceso: solo el admin publica — RLS), A03 (sanitización del contenido para evitar XSS, por ser contenido publicado que ven todos los residentes) y A05 (configuración). Documentada en /docs/seguridad/owasp-checklist.md. Cumple el criterio de seguridad de DoD v3. 2 h, P2.

Emergente absorbido (buffer): PBI-S9-E02 — recordatorio de factura también el día del vencimiento (además de los 3 días antes del S9), reusando el fixture de tiempo determinista (Acción 2 del Retro S11) en su E2E. 1 h, P2.

PBIs emergentes — entran en Sprints futuros

ID	Historia	Prior.	Horas est.	Sprint
PBI-S12-E01	Anuncios urgentes también por email (reusa Resend) (feedback Laura)	● P3	1.5 h	13
PBI-S12-E02	Indicador de lectura para el admin (cuántos residentes leyeron) (feedback Carlos)	● P2	2 h	13
PBI-S11-E01	Enlace al desglose del pedido desde el detalle de la factura	● P3	1 h	13
PBI-S11-E03	Exportar pedidos a CSV por rango	● P3	1.5 h	13
PBI-S10-E01	Vista rápida (quick view) del producto	● P3	1.5 h	13
PBI-S6-E03	Sesiones activas + cerrar todas al cambiar contraseña	● P2	2 h	13
PBI-S7-E01	Filtros por categoría en el dashboard de métricas	● P2	1 h	13
PBI-S11-E02	Cancelar pedido confirmado y devolver stock	● P2	2 h	Sin asignar

6 ESTADO DEL BACKLOG TRAS SPRINT 12

Progreso acumulado

Sprint	Horas	Incremento entregado	Estado
Sprint 0–6	93 h	Setup + Auth + Panel admin + Mantenimiento v1/v2 + Trazabilidad + Realtime	✓ Completado
Sprint 7	13 h	Métricas y Dashboard visual: KPIs + gráficas Recharts + CSV + vista materializada	✓ Completado
Sprint 8	13 h	Facturación v1: emisión individual/lote + vista residente + notificación Realtime	✓ Completado
Sprint 9	12.5 h	Facturación v2: marcar pagada + recordatorios + vencida + comprobante PDF + /health	✓ Completado
Sprint 10	13 + 8 h	Tienda interna v1: catálogo + CD a staging · Addendum del profesor (seed 3 años + pago simulado + encuesta SUS)	✓ Completado
Sprint 11	13 h	Tienda interna v2: carrito + descuento atómico + pedido → factura mensual + vista admin de pedidos · primer DoD v3	✓ Completado
Sprint 12	13 h	★ Comunicación: tablón de anuncios del edificio (admin publica comunicados con imagen + residente los recibe en vivo y marca leído) + OWASP · absorbe PBI-S9-E02	✓ Completado
Sprint 13	13 h (est.)	Panel integral del residente (3 tarjetas) + sesiones activas	→ Próximo
Sprint 14	13 h (est.)	★ Dashboard ejecutivo del dueño + Release Candidate + demo final integral	■ Planificado

Total invertido: 170.5 horas en 13 sprints (Sprint 0 → Sprint 12), más 8 h del addendum de mejoras del profesor incorporado al Sprint 10 (178.5 h en total).

Total restante: ~26 horas estimadas en 2 sprints (S13–S14).

Velocidad promedio: 13.1 horas/sprint (estable por décimo sprint consecutivo).

Roadmap actualizado tras Sprint 12 Review

Sprint	Sem.	Objetivo principal — Entregable funcional
S13	15	Panel integral del residente: una sola vista con 3 tarjetas (solicitudes activas + facturas pendientes + pedidos del mes) + sesiones activas + emergentes (quick view S10-E01, desglose del pedido S11-E01, export de pedidos S11-E03, anuncios por email S12-E01, indicador de lectura S12-E02). Chore: Lighthouse ≥ 80
S14	16	★ Dashboard ejecutivo del dueño (Mantenimiento + Finanzas + Tienda) + Release Candidate (tag v1.0.0-rc) + demo final integral del producto

Nota: los emergentes del S12 se ubican — PBI-S12-E01 (anuncios urgentes por email) y PBI-S12-E02 (indicador de lectura) en S13. El módulo de Comunicación queda con el tablón de anuncios en vivo. El Web Push avanzado se mantiene como mejora opcional post-curso (las notificaciones Realtime + email del S6 ya cubren el aviso). El S13 consolida la experiencia del residente en una sola vista y el S14 cierra el curso con el dashboard ejecutivo del dueño.

Vista previa Sprint 13 — Panel integral del residente

"Sprint 13: dar al residente una vista única (su 'home') con 3 tarjetas — solicitudes activas, facturas pendientes y pedidos del mes — que reemplaza al dashboard simple actual. Incluye sesiones activas. Chore: auditoría Lighthouse (≥ 80) en la nueva /residente. DoD v3."

PBI	Historia	Horas est.	Prior.
HU-HOME-01	Vista /residente como dashboard integral con 3 tarjetas (grid responsive)	4 h	● P1
HU-HOME-02	Tarjeta 'Solicitudes activas' con badge de estado + últimos cambios	2 h	● P1
HU-HOME-03	Tarjeta 'Facturas pendientes' con total a pagar y próximo vencimiento	2 h	● P1
HU-HOME-04	Tarjeta 'Pedidos del mes' con resumen de unidades y total acumulado	2 h	● P1
PBI-S6-E03	Sesiones activas + cerrar todas al cambiar contraseña	2 h	● P2
Chore-T	Auditoría Lighthouse ≥ 80 en /residente + revisión de cobertura de tests	1 h	● P2

Total estimado Sprint 13: 13 horas + 2 h de buffer (los emergentes priorizados — quick view, desglose del pedido, export de pedidos, anuncios por email, indicador de lectura — compiten por el buffer según el PO).

Variables de entorno acumuladas al Sprint 12

Este Sprint no añade variables nuevas; el tablón de anuncios reusa Storage, Realtime y Resend ya configurados. La tabla acumulada se mantiene en las del S10:

Variable	Descripción	Dónde se usa	Desde
VITE_SUPABASE_URL	URL pública del proyecto Supabase	Frontend (cliente JS) · dummy en CI	Sprint 0
VITE_SUPABASE_ANON_KEY	Clave anónima de Supabase	Frontend (cliente JS) · dummy en CI	Sprint 0
SUPABASE_SERVICE_ROLE_KEY	Clave de servicio (admin) de Supabase	Edge Functions (servidor) · /health	Sprint 3
RESEND_API_KEY	Clave de API de Resend para emails	Edge Functions (recordatorio / factura)	Sprint 2

Variable	Descripción	Dónde se usa	Desde
RESEND_FROM_ADDRESSES	Remitente de los emails de notificaciones	Edge Function recordatorios-facturas	Sprint 6
SUPABASE_DB_URL	URL de conexión directa a la BD	Migraciones locales · pg_cron	Sprint 0
VERCEL_TOKEN	Token de despliegue de Vercel	GitHub Actions (CD a staging)	Sprint 10
VERCEL_ORG_ID	ID de la organización en Vercel	GitHub Actions (CD a staging)	Sprint 10
VERCEL_PROJECT_ID	ID del proyecto en Vercel	GitHub Actions (CD a staging)	Sprint 10

Variables proyectadas para futuros Sprints:

- S13 (Panel integral) y S14 (Dashboard ejecutivo + RC): no requieren secretos nuevos; Lighthouse y el release candidate se apoyan en la configuración existente.

Ninguna de estas variables debe aparecer en el código fuente ni en commits. Todas van en .env.local (local) y en Secrets de GitHub/Vercel (CI/CD).

— Zity · Artefactos Sprint 12 · Documento vivo — actualizar en cada Sprint Review —